CYBERBOT

Yapay Zeka Destekli Siber Güvenlik Asistanı

Yazılım Gereksinim Belirtimi (SRS)

Sürüm 1.0 · 22 Ekim 2026 · ISO/IEC/IEEE 29148 uyumlu

Doküman	Yazılım Gereksinim Belirtimi (SRS)
Ürün	CYBERBOT — Yapay Zeka Destekli Siber Güvenlik Asistanı
Sürüm / Tarih	1.0 / 22 Ekim 2026
Hazırlayan	CYBERBOT Proje Ekibi
Kapsam	Kimlik doğrulama, 2FA, hesap kurtarma, admin, AI sohbet, güvenlik ve operasyon
Durum	Sürüm 1.0 · uygulama durumu izlenen gereksinim seti

Bu belge; CYBERBOT'un işlevsel ve işlevsel olmayan gereksinimlerini, kabul ölçütlerini, doğrulama yöntemlerini ve üretim kısıtlarını tanımlar. Gerçek sırlar, API anahtarları ve kullanıcı verileri belgeye dahil edilmemiştir.

İçindekiler

1. Giriş 4
1.1 Amaç 4
1.2 Kapsam 4
1.3 Hedef Kitle 4
1.4 Tanımlar ve Kısaltmalar 4
1.5 Referanslar 4

2. Genel Tanım 5
2.1 Ürün Perspektifi 5
2.2 Ürün İşlevleri 5
2.3 Kullanıcı Sınıfları 5
2.4 Çalışma Ortamı 5
2.5 Tasarım ve Uygulama Kısıtları 5
2.6 Varsayımlar ve Bağımlılıklar 5
2.7 Kapsam Dışı 6

3. İşlevsel Gereksinimler 7
3.1 Kayıt ve E-posta Doğrulama 7
3.2 İki Faktörlü Doğrulama Kaydı 7
3.3 Giriş, Oturum ve Yetkilendirme 8
3.4 Parola Sıfırlama 8
3.5 Hesap ve Profil 8
3.6 Admin Koruması 8
3.7 AI Sohbet 9
3.8 Denetim ve Loglama 9
3.9 Güvenlik Başlıkları ve Taşıma 10
3.10 Operasyon ve Dağıtım 10

4. Dış Arayüz Gereksinimleri 11
4.1 Kullanıcı Arayüzü 11
4.2 API Arayüzü 11
4.3 Yazılım ve İletişim Arayüzleri 11

5. İşlevsel Olmayan Gereksinimler 12

6. Veri Gereksinimleri 13
6.1 Veri Koruması 13

7. İzlenebilirlik ve Kabul 14
7.1 Test ve Kanıt Özeti 14
7.2 Gereksinim → Test İzlenebilirliği 14
7.3 Kabul Ölçütleri 14

8. Riskler ve Azaltmalar 15

9. Ekler 16

Ek A. Ortam Değişkenleri 16

Ek B. Sözlük 16

Ek C. Değişiklik Kaydı 16

Ek D. Onay 16

Sayfa numaraları PDF oluşturulurken otomatik hesaplanmıştır.

1. Giriş

1.1 Amaç

Bu SRS, CYBERBOT'un güvenli kimlik doğrulama çekirdeği ve AI destekli sohbet özelliği için geliştirme, test, güvenlik incelemesi ve üretim kabulünde ortak referans olacak gereksinimleri tanımlar. Belge, hem mevcut sürümün uyguladığı davranışı hem de üretim için zorunlu operasyonel koşulları kapsar.

1.2 Kapsam

Kapsam: kullanıcı kaydı, e-posta doğrulama, TOTP tabanlı iki faktörlü doğrulama, yedek kurtarma kodları, oturum yönetimi, parola sıfırlama, profil ve hesap silme, Django admin koruması, AI sohbet API'si, hız sınırları, denetim kayıtları ve üretim yapılandırması. WebAuthn/passkey, OIDC/JWT sağlayıcılığı, mobil uygulama, dosya yükleme, ödeme ve çok kiracılılık kapsam dışıdır.

1.3 Hedef Kitle

1. Ürün sahibi ve proje yöneticisi: kapsam ve kabul ölçütleri.
2. Geliştirici ekip: işlevsel gereksinimler, veri modeli ve kısıtlar.
3. Güvenlik ekibi: tehdit modeli, doğrulama ve üretim kontrolleri.
4. Operasyon/DevOps: dağıtım, PostgreSQL, Redis, SMTP ve izleme.
5. Test ekibi: kabul testleri ve izlenebilirlik matrisi.

1.4 Tanımlar ve Kısaltmalar

Terim	Açıklama
2FA	İki faktörlü kimlik doğrulama.
TOTP	Zamana dayalı tek kullanımlık parola (RFC 6238).
CSRF	Cross-Site Request Forgery; siteler arası istek sahteciliği.
CSP	Content Security Policy; tarayıcı içerik güvenlik politikası.
SRI	Subresource Integrity; CDN varlık bütünlüğü doğrulaması.
SSRF	Server-Side Request Forgery; sunucu tarafı istek sahteciliği.
IdP	Identity Provider; kimlik sağlayıcı.
OIDC	OpenID Connect.
RBAC	Role-Based Access Control.
p95	İsteklerin %95'inin altında kaldığı gecikme değeri.

Tablo 1. Terimler ve kısaltmalar.

1.5 Referanslar

No	Kaynak
[1]	ISO/IEC/IEEE 29148:2018 — Systems and software engineering — Life cycle processes — Requirements engineering.
[2]	OWASP Top 10 (2021).
[3]	OWASP Application Security Verification Standard (ASVS) 4.x/5.x.
[4]	NIST SP 800-63B — Digital Identity Guidelines: Authentication and Lifecycle Management.
[5]	RFC 6238 — TOTP: Time-Based One-Time Password Algorithm.
[6]	Django 5.2 documentation — Authentication, CSRF, security settings.
[7]	Google Gemini API / google-genai SDK documentation.
[8]	Proje içi `SECURITY_TODO.md`, `README.md` ve test paketi.

Tablo 2. Referanslar.

2. Genel Tanım

2.1 Ürün Perspektifi

CYBERBOT, Django tabanlı bir web uygulamasıdır. Kullanıcı önce güvenli bir hesap oluşturur ve TOTP ile ikinci faktörü etkinleştirir; ancak bundan sonra AI sohbetine erişebilir. Ürün; kimlik doğrulama çekirdeği, tarayıcı arayüzü, AI orkestrasyonu ve operasyonel güvenlik kontrollerinden oluşur. Mevcut sürüm monolitiktir; güvenlik servisleri `core/services/` altında ayrıştırılmıştır.

2.2 Ürün İşlevleri

1. Kullanıcı kaydı, parola politikası ve e-posta doğrulama.
2. TOTP tabanlı 2FA kaydı, QR üretimi, kod doğrulama ve replay koruması.
3. Yedek kurtarma kodları ve TOTP ile yeniden üretim.
4. Parola sıfırlama ve güvenli oturum açma.
5. Profil yönetimi ve TOTP ile adım yükseltmeli hesap silme.
6. Django admin için 2FA, hız sınırı ve IP allowlist.
7. 2FA korumalı AI sohbet API'si ve güvenli çıktı render'ı.
8. Denetim kayıtları, JSON log ve hız sınırları.

2.3 Kullanıcı Sınıfları

Sınıf	Sorumluluk	Erişim
Son kullanıcı	Kayıt olur, 2FA kurar, sohbet eder, profilini yönetir.	Web tarayıcısı + authenticator uygulaması
Admin	Django admin üzerinden kullanıcı/2FA kayıtlarını yönetir.	Staff hesap + 2FA + izinli ağ
Operasyon	Dağıtım, yapılandırma, Redis/PostgreSQL/SMTP ve log yönetimi yapar.	Sunucu/CI erişimi
Güvenlik denetçisi	Audit log, erişim ve yapılandırma kanıtlarını inceler.	Salt-okunur log/konfigürasyon erişimi

Tablo 3. Kullanıcı sınıfları.

2.4 Çalışma Ortamı

Bileşen	Gereksinim
İstemci	Modern tarayıcı; JavaScript; authenticator uygulaması (TOTP).
Sunucu	Python 3.12; Django 5.2.17 LTS; WSGI/ASGI sunucu (üretimde Gunicorn/Uvicorn).
Veritabanı	Lokal SQLite; üretimde PostgreSQL 14+.
Cache	Lokal LocMem; üretimde Redis.
E-posta	Lokal console backend; üretimde SMTP.
AI	Google Gemini API; `google-genai` SDK; sunucu tarafı API anahtarı.
Ağ	HTTPS reverse proxy; güvenli cookie/HSTS; admin için IP allowlist.

Tablo 4. Çalışma ortamı.

2.5 Tasarım ve Uygulama Kısıtları

- Kimlik doğrulama Django'nun session modeli üzerine kuruludur; OIDC/JWT sağlayıcısı değildir.
- 2FA için TOTP kullanılır; WebAuthn/passkey bu sürümde yoktur.
- AI sohbeti streaming değildir; senkron istek/yanıt ve 30 saniye timeout vardır.
- Sohbet geçmişi kalıcı olarak saklanmaz.
- Üretimde SQLite ve LocMem kabul edilmez; PostgreSQL ve Redis zorunludur.
- Üretimde HTTPS, SMTP ve admin IP allowlist zorunludur.

2.6 Varsayımlar ve Bağımlılıklar

- Reverse proxy TLS'i sonlandırır ve doğru `Host`/`X-Forwarded-Proto` başlıklarını iletir.
- SMTP servisi erişilebilir ve gönderim politikaları (SPF/DKIM/DMARC) yapılandırılmıştır.
- Gemini API anahtarı ve kota yönetimi operasyon ekibi tarafından sağlanır.
- PostgreSQL ve Redis yönetilen/izlenen servisler olarak sunulur.

- Kullanıcıların TOTP uygulamasına erişimi vardır; yedek kodlar güvenli saklanır.
- Sistem saati NTP ile senkronizedir; TOTP ±1 adım toleransı vardır.

2.7 Kapsam Dışı

- OIDC/SAML sağlayıcılığı, sosyal giriş, kurumsal SSO.
- WebAuthn/passkey, donanım anahtarı, biyometrik doğrulama.
- Mobil uygulama, masaüstü istemci, çok kiracılı SaaS.
- Dosya yükleme, e-posta ekleri, sesli sohbet.
- Ödeme, faturalama, abonelik yönetimi.
- Tam SIEM, WAF, DDoS koruması ve hukuki uyum sertifikasyonu.

3. İşlevsel Gereksinimler

Öncelikler MoSCoW'dir: Must (zorunlu), Should (beklenen), Could (opsiyonel). Durum sütunu mevcut sürümün uygulama durumunu gösterir. Her gereksinim en az bir kabul/doğrulama yöntemiyle eşleştirilmiştir.

3.1 Kayıt ve E-posta Doğrulama

ID	Öncelik	Gereksinim	Kabul / Doğrulama	Durum
FR-REG-001	Must	Kullanıcı; kullanıcı adı, e-posta, ad, soyad ve parola ile kayıt olabilmelidir. Kullanıcı adı benzersiz olmalı; hata mesajı hesap detayını onaylamamalıdır.	Form testi; benzersizlik testi; genel mesaj kontrolü.	Uygulandı
FR-REG-002	Must	Parola en az 8 karakter, büyük/küçük harf, rakam ve özel karakter içermelidir. Django common-password ve similarity validatörleri uygulanmalıdır.	`RegisterForm` testleri; `validate_password`; Argon2 hash kontrolü.	Uygulandı
FR-REG-003	Must	Kayıt sırasında `UserTwoFactor` oluşturulmalı ve TOTP secret'ı şifreli saklanmalıdır. Kullanıcı 2FA tamamlanmadan login edilmemelidir.	Signup testi; DB'de `gAAAA...` kontrolü.	Uygulandı
FR-REG-004	Must	Kayıt istekleri IP başına saatte 10 ile sınırlandırılmalıdır (yapılandırılabilir).	Rate-limit testi; 429 kontrolü.	Uygulandı
FR-VER-001	Must	E-posta doğrulama etkinse, doğrulanmamış kullanıcı 2FA kurulumuna geçememelidir. Token 24 saat geçerli ve tek kullanımlık olmalıdır.	`EmailVerificationTests`; token tekrar kullanımı; setup blok testi.	Uygulandı
FR-VER-002	Should	Doğrulama e-postası yeniden gönderilebilmelidir; yanıt hesap varlığını açıklamamalı ve IP başına saatte 5 ile sınırlı olmalıdır.	Resend testi; genel yanıt; rate limit.	Uygulandı
FR-VER-003	Must	E-posta doğrulama özelliğinden önce var olan kullanıcılar doğrulanmış sayılmalıdır.	`0006` veri migrasyonu; regresyon testi.	Uygulandı

Tablo 5. Kayıt ve e-posta doğrulama gereksinimleri.

3.2 İki Faktörlü Doğrulama Kaydı

ID	Öncelik	Gereksinim	Kabul / Doğrulama	Durum
FR-2FA-001	Must	Normal kayıt akışındaki kullanıcı, aynı oturumda token olmadan 2FA kaydını tamamlayabilmelidir.	Signup → setup → TOTP → recovery codes testi.	Uygulandı
FR-2FA-002	Must	Mevcut/admin hesaplar için 2FA kaydı, en az 15 dakika geçerli, tek kullanımlık ve yalnızca hash'i saklanan enrollment token ile yapılmalıdır.	Token'sız QR yok; geçerli token ile QR; tekrar kullanım reddi.	Uygulandı
FR-2FA-003	Must	QR/provisioning URI üretilmeli; 6 haneli TOTP ±1 adım toleransla doğrulanmalı; aynı kod tekrar kabul edilmemelidir.	`last_used_step`; replay testi.	Uygulandı
FR-2FA-004	Must	2FA'sı etkin ve secret'ı mevcut hesaplar için QR/secret gösterilmemelidir.	Etkin hesap setup → profile redirect; içerik kontrolü.	Uygulandı
FR-2FA-005	Must	2FA etkinleştirildiğinde 10 adet tek kullanımlık yedek kod üretilmeli; kodlar yalnızca hash olarak saklanmalı ve bir kez gösterilmelidir.	`RecoveryCodeTests`; hash/one-time testi.	Uygulandı
FR-2FA-006	Should	Kullanıcı, geçerli TOTP kodu ile yedek kodlarını yeniden üretebilmelidir.	Profil formu; TOTP step-up testi.	Uygulandı
FR-2FA-007	Must	TOTP secret'ları Fernet ile şifrelenmeli; anahtar `TOTP_ENCRYPTION_KEY` ile yönetilmeli ve rotasyon desteklenmelidir.	Crypto testleri; çoklu anahtar desteği.	Uygulandı
FR-2FA-008	Must	Eski düz metin TOTP secret'ları migrasyonla şifrelenmelidir; geri alma davranışı tanımlı olmalıdır.	`0003` veri migrasyonu; yükseltme testi.	Uygulandı

Tablo 6. 2FA kayıt gereksinimleri.

3.3 Giriş, Oturum ve Yetkilendirme

ID	Öncelik	Gereksinim	Kabul / Doğrulama	Durum
FR-AUTH-001	Must	Parola doğrulaması Django `authenticate` ile yapılmalı; hatalı girişte kullanıcı/parola ayrımı yapılmamalıdır.	Login testleri; genel hata mesajı.	Uygulandı
FR-AUTH-002	Must	Parola doğru olsa bile 2FA tamamlanmadan gerçek oturum açılmamalı; pending durum 10 dakika ile sınırlı olmalıdır.	Session `_auth_user_id` yok; pending timeout testi.	Uygulandı
FR-AUTH-003	Must	TOTP veya yedek kod ile giriş yapılabilmeli; hatalı denemeler kullanıcı+IP ve IP bazlı sınırlandırılmalıdır.	`LoginTests`; 2FA lockout; recovery testi.	Uygulandı
FR-AUTH-004	Must	2FA tamamlanan oturumlar `auth_2fa_verified` ile işaretlenmeli; işaretsiz oturumlar korumalı sayfa/API'lerden çıkarılmalıdır.	Middleware testi; parola-only session reddi.	Uygulandı
FR-AUTH-005	Must	Django admin oturumu, 2FA işareti ve etkin faktör yoksa geçersiz sayılmalıdır.	`AdminProtectionTests`; admin redirect/logout.	Uygulandı
FR-AUTH-006	Must	Çıkış POST + CSRF ile yapılmalı ve oturum tamamen temizlenmelidir.	Logout testi; GET reddi.	Uygulandı
FR-AUTH-007	Must	Pending ve login geçişlerinde oturum anahtarı yenilenmelidir (fixation koruması).	`cycle_key()` kod incelemesi/testi.	Uygulandı

Tablo 7. Giriş ve oturum gereksinimleri.

3.4 Parola Sıfırlama

ID	Öncelik	Gereksinim	Kabul / Doğrulama	Durum
FR-RESET-001	Must	Kullanıcı e-posta ile parola sıfırlama bağlantısı isteyebilmeli; bağlantı 1 saat geçerli ve tek kullanımlık olmalıdır. Yanıt hesap varlığını açıklamamalıdır.	`PasswordResetTests`; `mail.outbox`; tek kullanım.	Uygulandı
FR-RESET-002	Must	Parola sıfırlama 2FA'yı atlamamalı; yeni parola ile giriş yine TOTP/yedek kod istemelidir.	Reset sonrası login → verify-2fa testi.	Uygulandı
FR-RESET-003	Must	Sıfırlama istekleri IP başına saatte 5 ile sınırlandırılmalıdır.	Rate-limit testi; 429.	Uygulandı
FR-RESET-004	Should	E-posta backend'i lokal console, üretimde SMTP olarak yapılandırılabilmelidir.	Settings/env; prod fail-fast.	Uygulandı

Tablo 8. Parola sıfırlama gereksinimleri.

3.5 Hesap ve Profil

ID	Öncelik	Gereksinim	Kabul / Doğrulama	Durum
FR-ACC-001	Must	Doğrulanmış kullanıcı kendi ad/soyad/e-posta bilgisini görüntüleyip güncelleyebilmelidir.	Profil testi; auth+2FA middleware.	Uygulandı
FR-ACC-002	Must	Hesap silme POST + geçerli TOTP step-up ile yapılmalı; hatalı kodda hesap silinmemelidir.	`AccountDeletionTests`; 400/redirect.	Uygulandı
FR-ACC-003	Should	Profil ekranı, TOTP doğrulamalı yedek kod yeniden üretimi sunmalıdır.	Regenerate testi; 10 yeni kod.	Uygulandı
FR-ACC-004	Could	Hesap aktivitesi ve güvenlik bildirimleri (yeni cihaz, parola/2FA değişimi) gösterilmelidir.	Gelecek sürüm.	Planlandı

Tablo 9. Hesap ve profil gereksinimleri.

3.6 Admin Koruması

ID	Öncelik	Gereksinim	Kabul / Doğrulama	Durum
FR-ADM-001	Must	Admin erişimi staff yetkisi + 2FA doğrulanmış oturum gerektirmelidir.	Admin testleri; parola-only reddi.	Uygulandı
FR-ADM-002	Must	Admin login denemeleri kullanıcı+IP bazlı sınırlandırılmalı ve audit edilmelidir.	Canlı PoC: 5 hatalı → 429; log.	Uygulandı
FR-ADM-003	Must	Admin erişimi CIDR/IP allowlist ile kısıtlanabilmeli; üretimde zorunlu olmalıdır.	Allowlist testi: 403/200; prod fail-fast.	Uygulandı
FR-ADM-004	Must	Şifreli TOTP secret'ı admin arayüzünde görüntülenememelidir.	`UserTwoFactorAdmin.exclude` kontrolü.	Uygulandı

Tablo 10. Admin gereksinimleri.

3.7 AI Sohbet

ID	Öncelik	Gereksinim	Kabul / Doğrulama	Durum
FR-AI-001	Must	Sohbet API'si yalnızca kimliği doğrulanmış, 2FA'sı etkin ve CSRF token'ı geçerli oturumlara açık olmalıdır.	`ChatApiTests`; 401/403/CSRF.	Uygulandı
FR-AI-002	Must	İstek `application/json` olmalı; mesaj 1–2000 karakter, gövde en fazla 64 KB olmalıdır.	415/413/400 testleri.	Uygulandı
FR-AI-003	Must	Kullanıcı başına dakikada 20 sohbet isteği sınırı uygulanmalıdır (yapılandırılabilir).	Rate-limit testi; 429.	Uygulandı
FR-AI-004	Must	Boş mesaj, kontrol karakterleri ve bariz prompt-injection/jailbreak kalıpları reddedilmelidir.	`ChatApiTests`; injection 400.	Uygulandı
FR-AI-005	Must	Mesaj, yapılandırılmış Gemini modeline sistem talimatı ile gönderilmeli; 30 saniye timeout ve 2048 token çıktı sınırı uygulanmalıdır.	`core/ai.py`; config testi.	Uygulandı
FR-AI-006	Must	Model çıktısı kontrol karakterlerinden temizlenmeli, 8000 karakterle sınırlanmalı; hata durumunda sır sızdırmayan 502/503 dönülmelidir.	Sanitizasyon testi; hata yolları.	Uygulandı
FR-AI-007	Must	Çıktı HTML olarak yorumlanmamalı; DOM `textContent`/düğümleriyle gösterilmelidir.	Kod taraması; XSS testi.	Uygulandı
FR-AI-008	Should	Sohbet geçmişi kalıcı olarak saklanmamalıdır.	Veri modeli incelemesi.	Uygulandı
FR-AI-009	Could	Model tabanlı moderasyon ve düzenli değerlendirme seti eklenmelidir.	Gelecek sürüm.	Planlandı
FR-AI-010	Must	Kullanıcı kontrollü URL ile sunucu tarafı istek atılmamalıdır (SSRF yok).	Sink taraması; sabit Gemini endpoint'i.	Uygulandı

Tablo 11. AI sohbet gereksinimleri.

3.8 Denetim ve Loglama

ID	Öncelik	Gereksinim	Kabul / Doğrulama	Durum
FR-LOG-001	Must	Kimlik doğrulama olayları user id, IP ve kullanıcı adı hash'i ile audit edilmelidir.	`AuditLoggingTests`; log formatı.	Uygulandı
FR-LOG-002	Must	Admin giriş hataları/kilitleri, 2FA hataları, parola sıfırlama, e-posta doğrulama, hesap silme ve sohbet blokları loglanmalıdır.	Testler; canlı log.	Uygulandı
FR-LOG-003	Should	JSON log opsiyonu ve kilit olayları için WARNING seviyesi bulunmalıdır.	JSON formatter testi.	Uygulandı
FR-LOG-004	Should	Loglar SIEM'e aktarılabilir olmalı; saklama ve alarm eşikleri tanımlanmalıdır.	Ortam entegrasyonu.	Kısmi
FR-LOG-005	Must	Loglarda parola, TOTP kodu, ham token veya API anahtarı bulunmamalıdır.	Kod incelemesi; testler.	Uygulandı

Tablo 12. Denetim ve log gereksinimleri.

3.9 Güvenlik Başlıkları ve Taşıma

ID	Öncelik	Gereksinim	Kabul / Doğrulama	Durum
FR-SEC-001	Must	Tüm durum değiştiren formlar ve sohbet API'si CSRF korumalı olmalıdır.	CSRF testi; 403.	Uygulandı
FR-SEC-002	Must	Uygulama sayfalarında nonce tabanlı CSP; admin için uyumlu CSP uygulanmalıdır.	Canlı header; nonce eşleşmesi.	Uygulandı
FR-SEC-003	Must	CDN varlıkları SRI ile yüklenmeli; Bootstrap 5.3.8 kullanılmalıdır.	HTML/SRI testi.	Uygulandı
FR-SEC-004	Must	`Permissions-Policy`, `X-Frame-Options: DENY`, `nosniff`, `Referrer-Policy`, COOP başlıkları bulunmalıdır.	Canlı header testi.	Uygulandı
FR-SEC-005	Must	Cookie'ler HttpOnly ve SameSite=Lax; üretimde Secure olmalıdır.	Settings/header testi.	Uygulandı
FR-SEC-006	Must	Üretimde güvenli olmayan yapılandırma uygulamayı başlatmamalıdır (fail-fast).	Prod config testi.	Uygulandı
FR-SEC-007	Must	`ALLOWED_HOSTS` açık olmalı; üretimde `*` kabul edilmemelidir.	Host header 400; fail-fast.	Uygulandı
FR-SEC-008	Must	SSRF sink'i bulunmamalı; dış çağrı sabit Gemini endpoint'ine yapılmalıdır.	Kod taraması; SSRF değerlendirmesi.	Uygulandı
FR-SEC-009	Must	Enrollment, recovery ve e-posta token'ları yalnızca hash olarak saklanmalıdır.	Model/kod incelemesi; testler.	Uygulandı
FR-SEC-010	Must	Sır dosyaları repo dışında ve 0600 izinli olmalıdır.	`git check-ignore`; `ls -l`.	Uygulandı

Tablo 13. Güvenlik ve taşıma gereksinimleri.

3.10 Operasyon ve Dağıtım

ID	Öncelik	Gereksinim	Kabul / Doğrulama	Durum
FR-OPS-001	Must	Kurulum; migrate, collectstatic ve env tabanlı yapılandırma ile tekrarlanabilir olmalıdır.	README; CI.	Uygulandı
FR-OPS-002	Must	Üretimde PostgreSQL `DATABASE_URL` ve Redis `REDIS_URL` zorunlu olmalıdır.	Settings fail-fast; lock install.	Uygulandı
FR-OPS-003	Must	Bağımlılıklar hash'li lock ile kurulmalı; CI test/Bandit/pip-audit çalıştırmalıdır.	`.github/workflows/security.yml`; temiz venv.	Uygulandı
FR-OPS-004	Should	Health/readiness ve metrik uç noktaları bulunmalıdır.	Gelecek sürüm.	Planlandı
FR-OPS-005	Must	Admin erişimi IP allowlist ile sınırlandırılmalıdır.	Middleware testi.	Uygulandı
FR-OPS-006	Should	Üretimde Gunicorn/Uvicorn + reverse proxy kullanılmalı; `runserver` kullanılmamalıdır.	Dağıtım runbook.	Planlandı
FR-OPS-007	Should	PostgreSQL yedekleme/geri yükleme ve anahtar rotasyon runbook'u bulunmalıdır.	Operasyon dokümanı.	Planlandı

Tablo 14. Operasyon gereksinimleri.

4. Dış Arayüz Gereksinimleri

4.1 Kullanıcı Arayüzü

Sayfa	Yol	Amaç
Ana sayfa	/	Karşılama ve oturum açmış kullanıcı için sohbet.
Kayıt	/signup/	Hesap oluşturma.
2FA kurulumu	/setup-2fa/	QR, enrollment token ve TOTP doğrulama.
Giriş	/login/	Parola ile ilk adım.
2FA doğrulama	/verify-2fa/	TOTP veya yedek kod.
Yedek kodlar	/recovery-codes/	Tek seferlik kod gösterimi.
Profil	/profile/	Bilgi güncelleme, kod yenileme, hesap silme.
Parola sıfırlama	/password-reset/	E-posta ile sıfırlama.
E-posta doğrulama	/verify-email/sent/	Doğrulama e-postası ve yeniden gönderim.
Admin	/admin/	Yetkili yönetim; 2FA + allowlist.

Tablo 15. Kullanıcı arayüzü sayfaları.

4.2 API Arayüzü

Metot	Yol	Kimlik / 2FA	Amaç
POST	/api/chat/	Oturum + 2FA + CSRF	AI sohbet isteği; JSON.
POST	/login/	Anonim	Parola doğrulama; pending oturum.
POST	/verify-2fa/	Pending oturum	TOTP veya yedek kod.
POST	/signup/	Anonim	Hesap oluşturma.
POST	/profile/delete/	Oturum + 2FA	Step-up TOTP ile hesap silme.
POST	/profile/recovery-codes/	Oturum + 2FA	Yedek kod yenileme.
POST	/password-reset/	Anonim	Sıfırlama e-postası.
GET	/verify-email/<token>/	Anonim	E-posta doğrulama.

Tablo 16. API uç noktaları.

4.3 Yazılım ve İletişim Arayüzleri

- SMTP: parola sıfırlama ve e-posta doğrulama; TLS ve kimlik doğrulama desteklenmelidir.
- Gemini API: HTTPS; sabit endpoint; API anahtarı sunucuda; 30 saniye timeout.
- PostgreSQL: `DATABASE_URL`; TLS ve bağlantı havuzu önerilir.
- Redis: `REDIS_URL`; rate-limit sayaçları için paylaşımlı cache.
- Reverse proxy: TLS sonlandırma, `Host` ve `X-Forwarded-Proto` başlıkları.

5. İşlevsel Olmayan Gereksinimler

Aşağıdaki gereksinimler ölçülebilir hedefler ve doğrulama yöntemleri içerir. 'Kısmi' veya 'Planlandı' olanlar mevcut sürümde tamamen karşılanmayan, üretim olgunlaşması için izlenmesi gereken alanlardır.

ID	Kategori	Gereksinim	Kabul / Doğrulama	Durum
NFR-SEC-001	Güvenlik	Kimlik doğrulama ve yetkilendirme OWASP ASVS L1/L2 kontrolleriyle uyumlu olmalıdır.	OWASP eşlemesi; testler; kod incelemesi.	Kısmi
NFR-SEC-002	Kriptografi	Parolalar Argon2; TOTP secret'ları Fernet; token'lar SHA-256 ile korunmalıdır.	Crypto testleri; DB kontrolü.	Uygulandı
NFR-SEC-003	Oturum	Cookie'ler HttpOnly/SameSite; üretimde Secure; oturum 8 saat; pending 10 dakika olmalıdır.	Settings; header testi.	Uygulandı
NFR-SEC-004	Girdi	Tüm kullanıcı girdileri tip, boyut ve içerik açısından doğrulanmalıdır.	Form/API testleri.	Uygulandı
NFR-SEC-005	Supply chain	Bağımlılıklar hash'li lock ile kurulmalı; CVE taraması CI'da çalışmalıdır.	pip-audit; lock install.	Uygulandı
NFR-SEC-006	AI	Model çıktısı güvenilmez kabul edilmeli; sanitize edilmeli ve HTML olarak yorumlanmamalıdır.	AI testleri; DOM incelemesi.	Uygulandı
NFR-PERF-001	Performans	Kimlik doğrulama yanıtları (e-posta hariç) p95 < 500 ms olmalıdır.	Yük testi; APM.	Planlandı
NFR-PERF-002	Performans	AI isteği en geç 30 saniye içinde timeout ile sonlanmalıdır.	Timeout testi.	Uygulandı
NFR-AVAIL-001	Erişilebilirlik	Üretim hedefi aylık %99,9; en az 2 uygulama replikası olmalıdır.	İzleme; dağıtım topolojisi.	Planlandı
NFR-SCALE-001	Ölçeklenebilirlik	Web katmanı durumsuz olmalı; oturum/cache paylaşımlı olmalıdır.	Mimari inceleme; Redis/Postgres.	Kısmi
NFR-MAINT-001	Bakım	Kritik akışlar otomatik testlerle korunmalı; migration'lar ileri/geri alınabilir olmalıdır.	58 test; migration testleri.	Uygulandı
NFR-USA-001	Kullanılabilirlik	Form hataları anlaşılır, mobil uyumlu ve erişilebilir olmalıdır.	UI incelemesi; manuel test.	Kısmi
NFR-PRIV-001	Gizlilik	Veri minimizasyonu; sohbet geçmişi saklanmamalı; loglarda PII/sır olmamalıdır.	Kod incelemesi; log örnekleri.	Uygulandı
NFR-COMP-001	Uyum	KVKK/GDPR veri işleme ve saklama politikası üretim öncesi tanımlanmalıdır.	Hukuk/uyum incelemesi.	Planlandı
NFR-OBS-001	Gözlemlenebilirlik	JSON log, hata oranı ve kilit olayları izlenebilir olmalıdır.	Log/SIEM; alarm.	Kısmi

Tablo 17. İşlevsel olmayan gereksinimler.

6. Veri Gereksinimleri

Veri modeli, kimlik doğrulama durumunu ve kurtarma kanallarını yönetecek şekilde tasarlanmıştır. Parola ve TOTP dışındaki token'lar yalnızca hash olarak saklanır; TOTP secret'ı geri okunabilmesi gerektiği için şifrelenir.

Varlık	Alanlar	Sınıflandırma	Saklama / Not
User	username, email, password, is_active, is_staff	Kişisel veri / kimlik	Hesap silinene kadar; parola Argon2.
UserTwoFactor	otp_secret (şifreli), is_enabled, last_used_step	Gizli / kimlik	Hesap silinene kadar; Fernet.
EnrollmentToken	user, token_hash, expires_at, used_at	Gizli / kısa ömürlü	15 dk; tek kullanım; hash.
RecoveryCode	user, code_hash, used_at	Gizli / kurtarma	Kullanılana veya yenilenene kadar; hash.
EmailVerification	user, token_hash, expires_at, verified_at	Kişisel / doğrulama	24 saat; tek kullanım; hash.
Session	session_key, data, expire_date	Oturum	8 saat; logout/expire ile silinir.
Audit log	event, user_id, ip, username_hash	Güvenlik kaydı	Harici SIEM/saklama politikası.

Tablo 18. Veri varlıkları ve saklama.

6.1 Veri Koruması

- Parolalar hiçbir zaman geri döndürülemez biçimde (Argon2) saklanır.
- TOTP secret'ları Fernet ile şifrelenir; anahtar kaybı 2FA kayıtlarını okunamaz hale getirir.
- Enrollment/recovery/e-posta token'ları yalnızca SHA-256 hash olarak saklanır.
- Üretimde PostgreSQL disk şifreleme/TDE ve şifreli yedekler önerilir.
- Loglarda ham kullanıcı adı, parola, TOTP kodu veya token bulunmaz.
- Sohbet mesajları kalıcı olarak saklanmaz; yalnızca Gemini'ye iletilir.

7. İzlenebilirlik ve Kabul

7.1 Test ve Kanıt Özeti

Doğrulama	Sonuç
`python manage.py test`	58 test OK
`bandit -r core config`	0 bulgu
`pip-audit -r requirements.lock`	Bilinen zafiyet yok
`manage.py check --deploy` (prod env)	Temiz
Temiz venv'de hash'li lock kurulumu	Başarılı
Canlı HTTP smoke test	200/404/400/403 beklendiği gibi
Admin throttle PoC	5 hatalı → 429
Enrollment token PoC	Token'sız QR yok; token'lı akış başarılı
Recovery code PoC	Tek kullanım; replay reddi
AI injection/sanitization	400 ve temiz çıktı

Tablo 19. Doğrulama özeti.

7.2 Gereksinim → Test İzlenebilirliği

Gereksinim Grubu	Ana Test / Kanıt	Durum
FR-REG / FR-VER	`EnrollmentTests`, `EmailVerificationTests`	Uygulandı
FR-2FA	`EnrollmentTokenTests`, `RecoveryCodeTests`, `SecretStorageTests`	Uygulandı
FR-AUTH	`LoginTests`, `AdminProtectionTests`, `AccountDeletionTests`	Uygulandı
FR-RESET	`PasswordResetTests`	Uygulandı
FR-ADM	`AdminHardeningTests`, `AdminProtectionTests`	Uygulandı
FR-AI	`ChatApiTests`	Uygulandı
FR-LOG	`AuditLoggingTests`	Uygulandı
FR-SEC	`AdminHardeningTests`; canlı header/CSRF testleri	Uygulandı
FR-OPS	CI, lock install, prod config testi	Uygulandı

Tablo 20. İzlenebilirlik matrisi.

7.3 Kabul Ölçütleri

- Tüm Must gereksinimleri uygulanmış ve ilgili test/kanıtla doğrulanmış olmalıdır.
- Üretim yapılandırması fail-fast kontrolünden geçmeli; `check --deploy` temiz olmalıdır.
- Kritik akışlarda (kayıt, giriş, 2FA, recovery, reset, silme, admin, chat) regresyon testi bulunmalıdır.
- Bilinen kritik/yüksek CVE bulunmamalı; bağımlılıklar hash'li lock ile kurulmalıdır.
- Admin erişimi 2FA + IP allowlist olmadan mümkün olmamalıdır.
- AI çıktısı HTML olarak yorumlanmamalı; injection/control karakter testleri geçmelidir.

8. Riskler ve Azaltmalar

Risk	Etki	Olasılık	Azaltma	Kalan Risk
Prompt injection / jailbreak	Konu dışı veya zararlı içerik	Orta	Regex filtre, çıktı sanitizasyonu, güvenli render, rate limit	Orta
CDN/üçüncü taraf compromise	Tarayıcıda XSS	Düşük	SRI, CSP, sürüm pinleme; self-host opsiyonu	Düşük
Admin panelinin public olması	Credential stuffing	Orta	2FA, throttle, IP allowlist, audit	Düşük
TOTP anahtar kaybı	2FA kayıtları okunamaz	Düşük	Anahtar yedeği, KMS, rotasyon planı	Orta
E-posta teslim edilebilirliği	Reset/verification başarısız	Orta	SPF/DKIM/DMARC, SMTP izleme, yeniden gönderim	Orta
Gemini kesintisi/maliyet	Sohbet 502/503; kota	Orta	Timeout, rate limit, generic hata, kota alarmı	Orta
Lockout DoS	Kullanıcı geçici olarak kilitlenir	Düşük	Kullanıcı+IP limiti, global yüksek eşik, Redis	Düşük
SQLite'ın üretimde kullanılması	Veri bütünlüğü/ölçek	Düşük	Prod fail-fast, PostgreSQL zorunluluğu	Düşük
WebAuthn eksikliği	Phishing/TOTP zayıflığı	Orta	Yol haritası; yedek kod ve 2FA	Orta
Kullanıcı adı enumerasyonu	Hesap keşfi	Düşük	Genel mesaj, rate limit; e-posta tabanlı kayıt opsiyonu	Düşük

Tablo 21. Risk kaydı.

9. Ekler

Ek A. Ortam Değişkenleri

Değişken	Amaç	Lokal	Üretim
DJANGO_DEBUG	Debug modu	False	False
DJANGO_ALLOW_INSECURE_HTTP	HTTP geliştirme kaçış kapısı	True	False
DJANGO_SECRET_KEY	Django imzalama anahtarı	Zorunlu	Zorunlu
DJANGO_ALLOWED_HOSTS	Host allowlist	localhost	Gerçek alan adı
DJANGO_CSRF_TRUSTED_ORIGINS	Proxy CSRF origin	Boş	Gerekliyse
DJANGO_SITE_URL	E-posta/enrollment tabanı	localhost:8081	https URL
TOTP_ENCRYPTION_KEY	TOTP secret şifreleme	Zorunlu	Zorunlu
DATABASE_URL	PostgreSQL	Boş	Zorunlu
REDIS_URL	Paylaşımlı cache	Boş	Zorunlu
ADMIN_IP_ALLOWLIST	Admin CIDR allowlist	Boş	Zorunlu
DJANGO_SECURE_COOKIES	Secure cookie	False	True
DJANGO_SECURE_SSL_REDIRECT	HTTPS redirect	False	True
DJANGO_SECURE_HSTS_SECONDS	HSTS	0	>0
DJANGO_REQUIRE_EMAIL_VERIFICATION	E-posta doğrulama	False	True
DJANGO_EMAIL_BACKEND	E-posta backend	console	smtp
DJANGO_LOG_JSON	JSON log	False	True
GEMINI_API_KEY	Gemini anahtarı	Varsa	Zorunlu
CHAT_RATE_LIMIT_PER_MINUTE	Sohbet limiti	20	İhtiyaca göre

Tablo 22. Ortam değişkenleri.

Ek B. Sözlük

Terim	Açıklama
Pending session	Parola doğrulandıktan sonra, 2FA tamamlanmadan önceki kısa ömürlü oturum.
Enrollment token	Mevcut/admin hesabın 2FA kaydını yetkilendiren tek kullanımlık token.
Recovery code	TOTP cihazı kaybolduğunda kullanılan tek kullanımlık yedek kod.
Step-up auth	Kritik işlem öncesi yeniden 2FA doğrulaması.
Fail-fast	Güvenli olmayan yapılandırmada uygulamanın başlamaması.
SRI	CDN dosyasının hash ile doğrulanması.
CSP nonce	Her istekte üretilen, yalnızca o sayfadaki inline script'e izin veren değer.

Tablo 23. Sözlük.

Ek C. Değişiklik Kaydı

Sürüm	Tarih	Açıklama	Hazırlayan
1.0	22 Ekim 2026	İlk SRS; uygulama ile eşleşen gereksinimler, kabul ölçütleri ve doğrulama sonuçları.	CYBERBOT Proje Ekibi

Tablo 24. Değişiklik kaydı.

Ek D. Onay

Rol	Ad / Unvan	İmza	Tarih
Hazırlayan			
Gözden geçiren			
Onaylayan			

Tablo 25. Onay imzaları.

— Belge sonu —